

CÓMO CREAR UN PROGRAMA DE RESPUESTA A INCIDENTES

Guía práctica para preparación, detección, análisis, contención, recuperación y mejora

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

Tabla de contenido

- Propósito y uso responsable
- 1. Fundamentos de respuesta a incidentes
- 2. Gobierno y estatuto del programa
- 3. Funciones y responsabilidades
- 4. Categorías y severidad
- 5. Preparación y capacidad
- 6. Detección y reporte
- 7. Triage y análisis inicial
- 8. Estrategia de contención
- 9. Erradicación y corrección
- 10. Recuperación y restauración
- 11. Manejo de evidencia y forense
- 12. Comunicaciones y notificaciones
- 13. Playbook de ransomware
- 14. Incidentes de nube e identidad
- 15. Incidentes de terceros y cadena de suministro
- 16. Incidentes de sistemas de IA
- 17. Ejercicios y pruebas
- 18. Métricas y mejora continua
- 19. Plan de implementación de 30/60/90 días
- 20. Lista de preparación operativa

Propósito y uso responsable

Este manual explica cómo crear, operar, probar y mejorar un programa de respuesta a incidentes de ciberseguridad. Está destinado a usos defensivos, legales, autorizados y éticos.

La seguridad humana, la privacidad, la integridad de la evidencia y las obligaciones legales deben mantenerse como prioridades durante toda investigación.

Modelo de severidad

Nivel	Criterios de ejemplo	Respuesta objetivo
Crítico	Riesgo para personas, interrupción mayor, robo confirmado de datos sensibles, ransomware activo o compromiso privilegiado amplio	Activación ejecutiva inmediata y respuesta continua
Alto	Impacto material, exposición limitada, atacante persistente o proveedor crítico comprometido	Activación rápida y actualizaciones frecuentes
Medio	Compromiso contenido con impacto limitado o intento creíble	Responsable el mismo día hábil y actualizaciones programadas
Bajo	Evento sospechoso con bajo impacto y sin compromiso confirmado	Cola normal con disposición documentada

1. Fundamentos de respuesta a incidentes

La respuesta a incidentes es una capacidad organizacional para prepararse, detectar, analizar, contener, erradicar, recuperar y aprender de incidentes de ciberseguridad.

NIST SP 800-61 Revisión 3 integra la respuesta a incidentes en la gestión del riesgo de ciberseguridad y la alinea con NIST Cybersecurity Framework 2.0.

2. Gobierno y estatuto del programa

Defina la misión, autoridad, alcance, patrocinador ejecutivo, horario de servicio, autoridad de escalamiento, derechos de decisión, límites legales y expectativas de informes.

El estatuto debe indicar quién puede aislar sistemas, deshabilitar cuentas, preservar evidencia, contratar asesores externos, contactar autoridades y comunicarse públicamente.

3. Funciones y responsabilidades

Cree un equipo multifuncional con operaciones de seguridad, TI, nube, identidad, asuntos legales, privacidad, recursos humanos, comunicaciones, continuidad, seguridad física y liderazgo ejecutivo.

Use una matriz RACI para que cada tarea crítica tenga un responsable y una cobertura de respaldo.

4. Categorías y severidad

Defina categorías como malware, ransomware, compromiso de identidad, exposición de datos, abuso de nube, actividad interna, denegación de servicio, compromiso de aplicaciones, incidente de proveedor e incidente de IA.

La severidad debe considerar impacto empresarial, sensibilidad de datos, seguridad, alcance, persistencia, exposición regulatoria, interrupción y capacidad del atacante.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

5. Preparación y capacidad

Mantenga inventarios precisos, sistemas fortalecidos, copias protegidas, registros centralizados, tiempo sincronizado, contactos probados, diagramas actuales, acceso de emergencia y playbooks documentados.

Prepare comunicaciones seguras fuera de banda por si el correo o las herramientas normales están comprometidos.

6. Detección y reporte

Cree varios canales de reporte para empleados, clientes, proveedores, herramientas automáticas e investigadores externos.

Defina la información mínima: reportante, hora, activos, comportamiento, ubicación de evidencia, impacto y acciones ya realizadas.

Registros principales

Registro	Propósito
Ticket de incidente	Cronología, propiedad, decisiones, acciones y estado
Registro de evidencia	Fuente, método, hash, almacenamiento, acceso y transferencias

Registro de decisiones	Contención, notificación, recuperación y aceptación de riesgo
Línea de tiempo	Secuencia normalizada de actividad ofensiva y defensiva
Informe posterior	Causas, impacto, lecciones, acciones y responsables

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

7. Triage y análisis inicial

Valide si el evento es un incidente, determine alcance y urgencia, identifique identidades y sistemas afectados, preserve evidencia volátil y asigne un comandante.

Evite conclusiones prematuras. Separe hechos confirmados, hipótesis, incógnitas y niveles de confianza.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

8. Estrategia de contención

La contención debe reducir el daño, preservar evidencia y evitar interrupciones innecesarias.

Las opciones incluyen deshabilitar cuentas, revocar tokens, aislar equipos, bloquear indicadores, restringir redes, suspender integraciones, rotar credenciales y retirar servicios vulnerables.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

9. Erradicación y corrección

Elimine artefactos maliciosos, cierre persistencia, corrija vulnerabilidades, repare configuraciones, reconstruya sistemas cuando exista baja confianza e invalide credenciales robadas.

No declare finalizada la erradicación hasta probar persistencia alternativa y compromisos relacionados.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

10. Recuperación y restauración

Restablezca servicios de manera controlada, valide integridad, aumente el monitoreo, obtenga aceptación del negocio y mantenga un plan de reversión.

Los criterios de recuperación deben ser medibles y aprobados por propietarios técnicos y empresariales.

RACI de ejemplo

Actividad	Responsable final	Ejecutor	Consultados
Declarar incidente crítico	Líder ejecutivo	Comandante del incidente	Legal y propietario del negocio
Aislar endpoint	Líder de operaciones de seguridad	SOC/EDR	Operaciones de TI
Notificar regulador	Líder legal/privacidad	Equipo legal/privacidad	Patrocinador ejecutivo
Restaurar servicio	Propietario del servicio	Equipo TI/nube	Seguridad y continuidad

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

11. Manejo de evidencia y forense

Preserve evidencia según requisitos legales, regulatorios, de seguros e internos. Documente hora, recolector, fuente, método, hashes cuando corresponda, transferencias, almacenamiento y acceso.

Use personal capacitado y herramientas aprobadas. No altere innecesariamente la evidencia original.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

12. Comunicaciones y notificaciones

Cree planes internos, ejecutivos, para clientes, reguladores, autoridades, aseguradoras y medios antes de un incidente.

Use hechos verificados, proteja información privilegiada, evite especulación, coordine tiempos y mantenga un registro de decisiones.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

13. Playbook de ransomware

Las prioridades incluyen vida y seguridad, contención, protección de identidades, evidencia, restauración desde copias confiables, coordinación legal y evaluación de robo de datos.

No suponga que el cifrado es el único impacto. Investigue credenciales, persistencia, movimiento lateral y exfiltración.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

14. Incidentes de nube e identidad

Los incidentes de nube suelen incluir tokens robados, permisos excesivos, secretos expuestos, automatización comprometida, aplicaciones OAuth maliciosas o cambios en los registros.

Revise registros del proveedor de identidad, acceso condicional, roles privilegiados, entidades de servicio, identidades de carga de trabajo, plano de control y acceso a datos.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

15. Incidentes de terceros y cadena de suministro

Exija notificación oportuna, alcance, indicadores, servicios afectados, estado de contención y evidencia necesaria para evaluar el impacto.

Mantenga contactos alternativos y opciones de continuidad para proveedores críticos.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

16. Incidentes de sistemas de IA

Pueden incluir inyección de instrucciones, filtración de datos, acciones autónomas inseguras, contaminación de modelos o RAG, herramientas de agentes comprometidas y abuso de identidades no humanas.

Contenga agentes, herramientas, índices, credenciales y endpoints. Preserve instrucciones, llamadas a herramientas, versiones y aprobaciones, protegiendo la privacidad.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.
- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

17. Ejercicios y pruebas

Use ejercicios de mesa, simulaciones técnicas, pruebas de comunicación, restauración de copias y ejercicios con proveedores.

Cada ejercicio debe producir hallazgos, responsables, fechas, nuevas pruebas y cambios documentados.

Controles prácticos

- Documente las decisiones y el responsable.
- Preserve evidencia antes de realizar cambios destructivos.

- Aplique privilegio mínimo y aprobación para acciones de alto impacto.
- Mantenga una cronología con hora normalizada.

18. Métricas y mejora continua

Mida preparación, tiempo de detección, análisis, contención y recuperación, recurrencia, calidad de evidencia, ejercicios, acciones vencidas y satisfacción de interesados.

Use las métricas para mejorar la capacidad, no para castigar a quien reporta incidentes.

19. Plan de implementación de 30/60/90 días

Primeros 30 días: patrocinio, estatuto, contactos, severidad, canal de reporte, playbooks prioritarios y registros mínimos.

Días 31-60: funciones, evidencia, comunicaciones, proveedores, ejercicios y capacidades técnicas de contención.

Días 61-90: ejercicio completo, corrección de brechas, automatización, lecciones aprendidas y aprobación ejecutiva.

20. Lista de preparación operativa

Use la siguiente lista antes de declarar operativo el programa.

Lista de verificación

- ☐ Patrocinador ejecutivo asignado
- ☐ Estatuto aprobado
- ☐ Contactos y escalamiento probados
- ☐ Matriz de severidad aprobada
- ☐ Playbooks prioritarios documentados
- ☐ Comunicación segura fuera de banda disponible
- ☐ Registros y sincronización horaria verificados
- ☐ Procedimiento de evidencia aprobado
- ☐ Contactos legales, privacidad, seguros y comunicaciones confirmados
- ☐ Autoridad de contención documentada
- ☐ Restauración de copias probada
- ☐ Procedimientos de nube e identidad probados

- ☐ Requisitos de notificación de proveedores establecidos
- ☐ Procedimientos para incidentes de IA incluidos cuando correspondan
- ☐ Ejercicio de mesa completado
- ☐ Acciones correctivas cerradas
- ☐ Métricas e informes ejecutivos establecidos
- ☐ Fecha de revisión anual programada

Referencias oficiales

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations](#)

[NIST Cybersecurity Framework 2.0](#)

[CISA Cybersecurity Incident and Vulnerability Response Playbooks](#)

[Microsoft incident response planning](#)

[Microsoft cloud security benchmark - Incident Response](#)

Licencia

Copyright © 2026 Alberto (Al) Leiva. Licencia CC BY-NC-SA 4.0.